

Documentación de seguridad y resiliencia

Clasificador de CVs con IA · Entrega Final · Arquitecto de Flujos IA · Rodrigo Benegas

Alcance: minimización de datos · gestión de secretos · error handlers · human-in-the-loop · anti-bucle · monitoreo

1. Principios de diseño

- 1. **Minimizar:** a cada servicio viaja solo lo que necesita para su tarea.
- 2. **Ningún secreto en el flujo:** las claves viven en las conexiones de Make; el blueprint, el repositorio y el video no las contienen.
- 3. **El humano decide antes de cualquier acción externa:** ningún correo llega a un candidato sin la aprobación explícita del reclutador.
- 4. **Fallar visible, no silencioso:** todo error deja rastro en dos lugares (la ficha y el registro) y se reintenta solo.
- 5. **Idempotencia por estado:** el estado de la ficha es la única fuente de verdad; ningún paso se repite si el estado ya cambió.

2. Minimización de datos

Dato	Notion	IA (Groq)	Gmail	Registro (DB4)	Justificación
Nombre y apellido	sí	sí	sí	sí (solo en el título)	Necesario para redactar el borrador y trazar la ejecución.
Correo del candidato	sí	no	solo como destinatario	solo en el detalle de envío	La IA no lo necesita para clasificar; se evita mandar identificadores de contacto a un tercero.
Resumen del CV	sí	sí	no	no	Es el insumo de la clasificación; no se copia al log ni a los emails.
Requisitos y contexto de la empresa	sí	sí	no	no	Contexto RAG acotado a la búsqueda + "General".
Resultado y justificación de la IA	sí	—	solo al reclutador	resumido	El candidato nunca recibe el puntaje ni la justificación.
IDs de páginas, thread IDs, mensajes de error	sí	no	no	sí	Metadatos operativos; no salen del entorno Notion/Make.
Datos sensibles (salud, religión, política, documento)	no se piden	prohibido en el prompt	no	no	El prompt de sistema instruye a la IA a no pedirlos ni mencionarlos.

Marco legal. Los datos corresponden a personas que se postulan voluntariamente (base de licitud: consentimiento e interés legítimo del proceso de selección, Ley 25.326 de Protección de Datos Personales en Argentina; principios equivalentes al RGPD). Derechos de acceso y supresión: borrar la fila de DB1 elimina el resumen del CV y los resultados; el registro conserva solo nombre, etapa y resultado. Retención recomendada: 12 meses desde el cierre de la búsqueda.

3. Gestión de secretos y accesos

Secreto	Dónde vive	Quién lo ve	Control
Token de Notion (integración pública)	Conexión de Make "Rodrigo's Notion Public connection"	Solo el propietario de la cuenta de Make	Alcance limitado a las páginas compartidas con la integración (las 4 bases y el dashboard).
API key de Groq	Conexión de Make "Rodrigo's Groq connection"	Solo el propietario	Rotable desde la consola de Groq sin tocar el flujo.
OAuth de Gmail	Conexión de Make "Rodrigo's Gmail connection"	Solo el propietario	Permiso de envío; revocable desde la cuenta de Google.
Blueprint exportado	Repositorio público	Cualquiera	Contiene solo IDs de conexión (números), nunca tokens. Al importarlo en otra cuenta hay que reasignar las conexiones.

Video demo	Público Seguridad y resiliencia · Clasificador de CVs con IA · Rodrigo Benegas · septiembre 2026	Cualquiera	Las claves y los emails reales quedan fuera de cámara u ocultos.
------------	---	------------	--

4. Manejo de errores

Cada módulo que depende de un servicio externo tiene su propio error handler. En todos los casos el primer paso es **guardar un registro del error** (DB4) y el segundo dejar la ficha en un estado visible (Error con el mensaje). Recién después se decide si reintentar o cerrar.

Módulo protegido	Falla típica	Handler (en orden)	Directiva	Resultado para el operador
5 · Groq (IA)	API caída, cuota, 429, timeout	Log DB4 (Error ✓, mensaje de la API) → DB1 Estado = Error + texto → Break	Break · reintento automático 3 veces cada 15 min · ejecuciones incompletas guardadas	Si el servicio vuelve, la ejecución se reanuda sola desde el módulo 5 y la ficha termina "En revisión". Si no, queda en Error con el motivo.
6 · Parse JSON	La IA devolvió texto que no cumple el contrato	Log DB4 → DB1 Estado = Error ("respuesta inválida") → Ignore	Ignore · cierra la ejecución sin reintentar (reintentar con la misma respuesta no sirve)	El humano vuelve a poner Pendiente y se genera una respuesta nueva.
7 · Gmail aviso HITL	Cuota de envío, OAuth vencido	Log DB4 → DB1 Estado = Error → Break	Break · 3 × 15 min	La clasificación no se pierde: al reanudar se reenvía el aviso y se actualiza la ficha.
10 · Gmail al candidato	Idem	Log DB4 → DB1 Estado = Error → Break	Break · 3 × 15 min	La ficha no pasa a Contactado hasta que el email sale de verdad.
14 · Gmail de cierre	Idem	Log DB4 → Break	Break · 3 × 15 min	Notificado sigue vacío: la ruta C se reintenta sola.
Cualquier otro (Notion)	429 / 5xx de Notion	Configuración del escenario: máximo 3 errores consecutivos, ejecuciones incompletas habilitadas	Make guarda la ejecución incompleta para reanudarla a mano	Aparece en "Incomplete executions" de Make con el módulo y el bundle exactos.

Por qué Break y no Resume. Resume inventa un valor de salida para seguir adelante; en este flujo eso significaría inventar una clasificación. Break detiene, guarda y reintenta cuando el servicio vuelve, que es el comportamiento correcto para fallas transitorias de una API. La única excepción es el Parse JSON, donde reintentar no cambia nada y por eso se usa Ignore.

5. Human-in-the-loop (HITL)

- **Acción crítica:** escribirle a un candidato (invitación o rechazo). Es irreversible y expone a la empresa.
- **Compuerta:** la ruta B exige Estado = En revisión y Aprobado = true ; la ruta C exige que el humano haya puesto Estado = Rechazado . El sistema puede clasificar y proponer, nunca decidir.
- **Notificación y espera:** el módulo 7 envía por email el resultado, la justificación, el borrador y el link a la ficha. El flujo no bloquea: la espera es el propio estado "En revisión". Puede durar minutos o semanas sin consumir operaciones.
- **Edición humana:** el reclutador puede corregir el Borrador de respuesta antes de aprobar; lo que se envía es la versión editada.
- **Trazabilidad:** el aviso, la aprobación (fecha de Última ejecución) y el envío quedan en DB4 y en el hilo de Gmail (respuesta en el mismo hilo).

6. Anti-bucle, tipos y límites

Filtro anti-bucle El trigger observa ítems editados, y Make edita ítems. Cada ruta termina cambiando el Estado (o marcando Notificado) y cada filtro exige el estado anterior, así que una ficha editada por Make no vuelve a entrar por la misma ruta. Costo máximo del retrigger: 2 operaciones.	Comparación de tipos correctos Estado se compara como texto, Aprobado y Notificado como booleanos, la existencia de datos con exist / notexist , y la experiencia es numérica en Notion para que la IA la compare con la mínima. No se comparan números como texto.
--	---

Límites de consumo

Trigger cada 15 min con límite de 10 fichas por ciclo (backpressure), `max_tokens = 700`, RAG con máximo 10 entradas, plan Free de Make con 1.000 ops/mes.

Seguridad y resiliencia · Clasificador de CVs con IA · Rodrigo Benegas · septiembre 2026

Cuotas externas

Groq (rate limit por minuto) y Gmail (500 envíos/día) se absorben con los reintentos de Break; Notion 429 con el límite de 10 ítems por ciclo.

7. Monitoreo y alertas

- **Dashboard público de Notion:** total de ejecuciones, tasa de errores (% de filas de DB4 con Error ✓), fichas por estado y por clasificación, tokens por ejecución.
- **Ficha en Error:** visible en la vista por estado con el motivo en el campo Error; la ruta D además avisa por email al reclutador.
- **Make:** historial de ejecuciones, ejecuciones incompletas y notificaciones por email cuando un escenario se desactiva por errores.

8. Plan de pruebas (test de estrés + camino infeliz)

#	Caso	Entrada	Resultado esperado
1	Candidata apta (backend)	5 años Node.js, datos completos	Ruta A → Apto, aviso al reclutador, Estado "En revisión", log OK
2	Candidato con menos experiencia que la mínima (marketing)	1 año, mínimo 2	Ruta A → Revisar o No apto con -20 puntos explicado
3	Candidata apta (backend, perfil mixto)	3 años full stack	Ruta A → Apto o Revisar; borrador coherente
4	Candidato apto (marketing)	4 años campañas pagas	Ruta A → Apto
5	Aprobación humana	Aprobado ✓ sobre el caso 1	Ruta B → email al candidato, "Contactado", respuesta en el hilo del reclutador, log OK
6	Rechazo humano	Estado = Rechazado sobre el caso 2	Ruta C → email de cierre, Notificado ✓, log OK
7	Camino infeliz: datos incompletos	Ficha sin Resumen del CV	Ruta D → Estado "Error" con "falta Resumen del CV", log con Error ✓, aviso al reclutador, sin llamada a la IA
8	Camino infeliz: sin correo	Ficha sin Correo electrónico	Ruta D → Error "falta Correo electrónico"

Los resultados reales de cada corrida (fecha, operaciones consumidas, tokens y capturas) están en el README del repositorio y en la carpeta `screenshots/`.

9. Riesgos residuales y mejoras

Riesgo	Impacto	Mitigación actual	Mejora propuesta
Inyección de instrucciones en el texto del CV	La IA podría alterar su criterio	Prompt de sistema con contrato estricto, salida JSON validada, revisión humana obligatoria antes de cualquier envío	Segunda pasada con un modelo distinto para los casos "Revisar"
Vencimiento del OAuth de Gmail o del token de Notion	El flujo se detiene	Break con reintentos + notificación de Make + estado Error visible	Alerta a un segundo email cuando el escenario se desactiva
Dependencia de un solo proveedor de IA	Caída de Groq	Reintentos; la ficha queda en Error con el motivo	Ruta de contingencia con OpenAI directo, activada por un flag en DB2
Costo del orquestador al escalar	Plan de Make	Retrigger acotado, una llamada por candidato	Trigger por webhook de Notion en vez de polling